

AGENTCON + MCPCON EUROPE 2026 · AMSTERDAM

We built AI agents to fix security findings in production

Here's what developers actually merged.

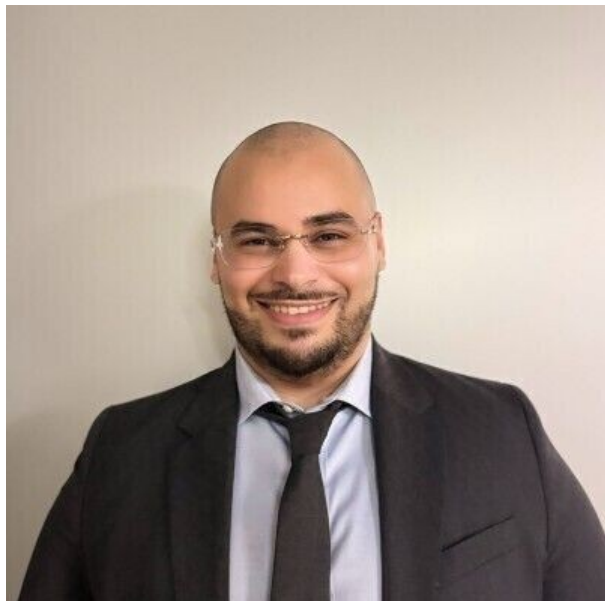
Amine Boudraa · Gianfranco Romani

Product Security · Thomson Reuters



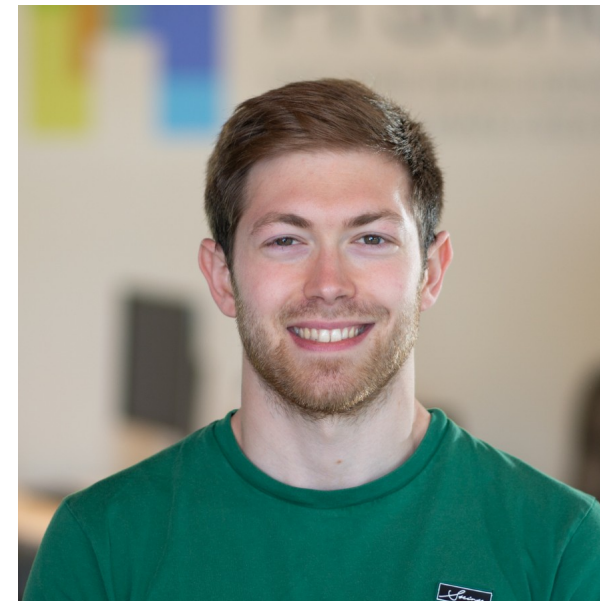
PRESENTERS

Today's presenters



Amine Boudraa

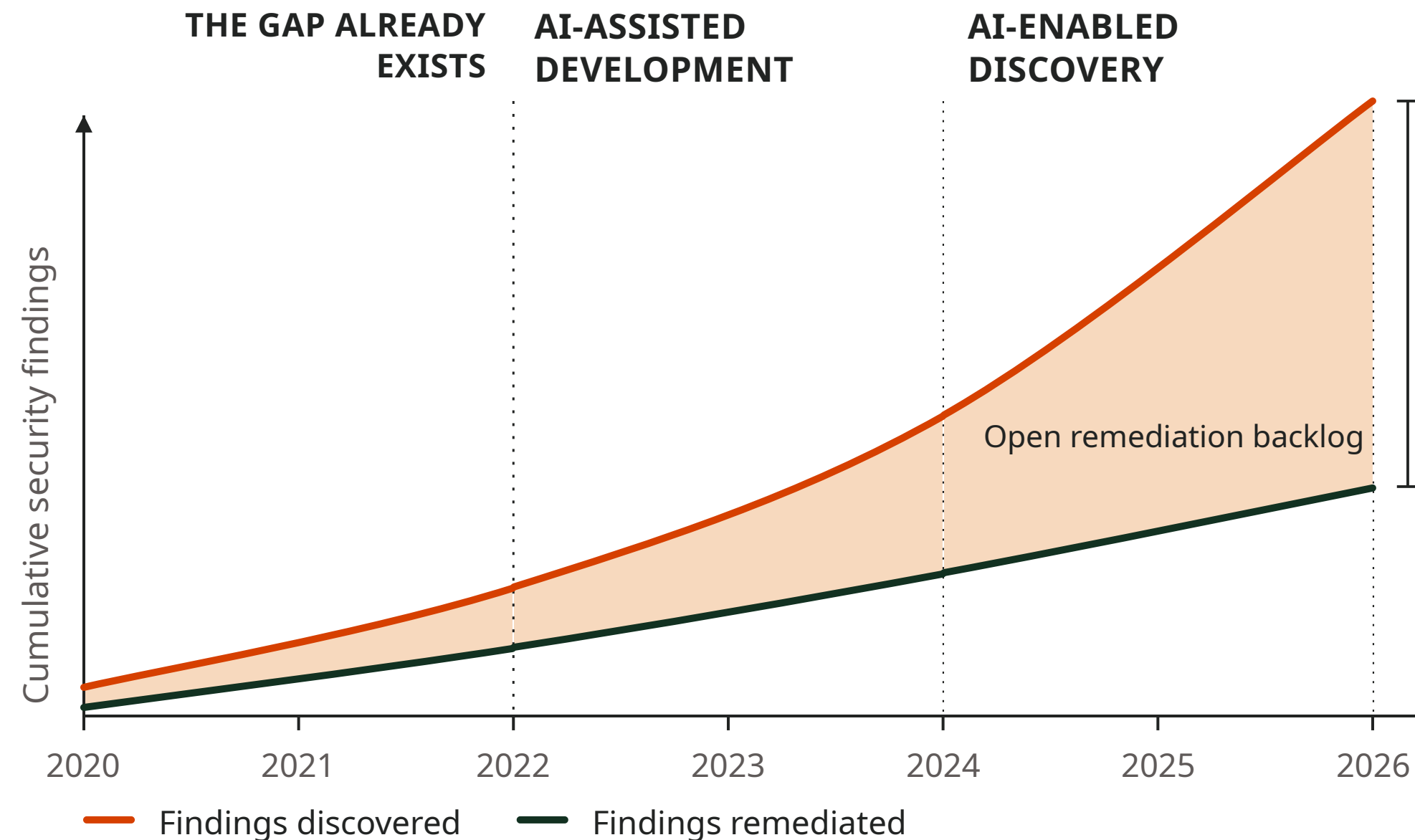
Senior Product Security Engineer



Gianfranco Romani

Senior ML Engineer · Cybersecurity

The state of vulnerability remediation



Conceptual model, not measured data

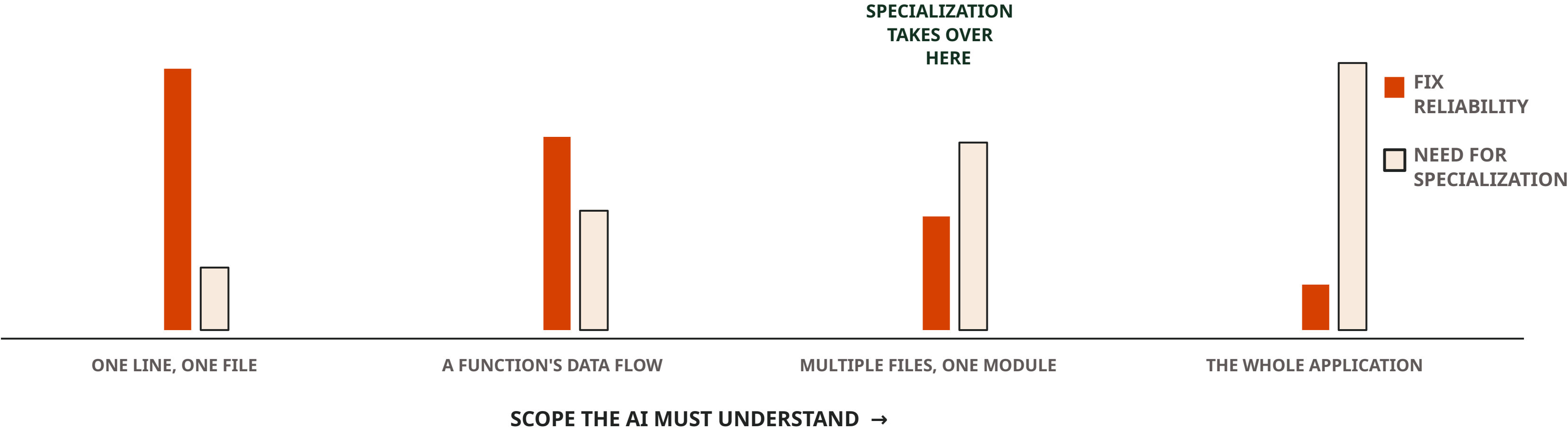
2025 — Vulnerability volume reaches record levels. NIST reports CVE submissions grew 263% from 2020 to 2025.

2026 — HackerOne's 2026 platform data reports vulnerability submissions up 76% year over year, while remediation improved only 19%.

Reducing this gap is our focus today

AI Assistants can help when the fix is cheap

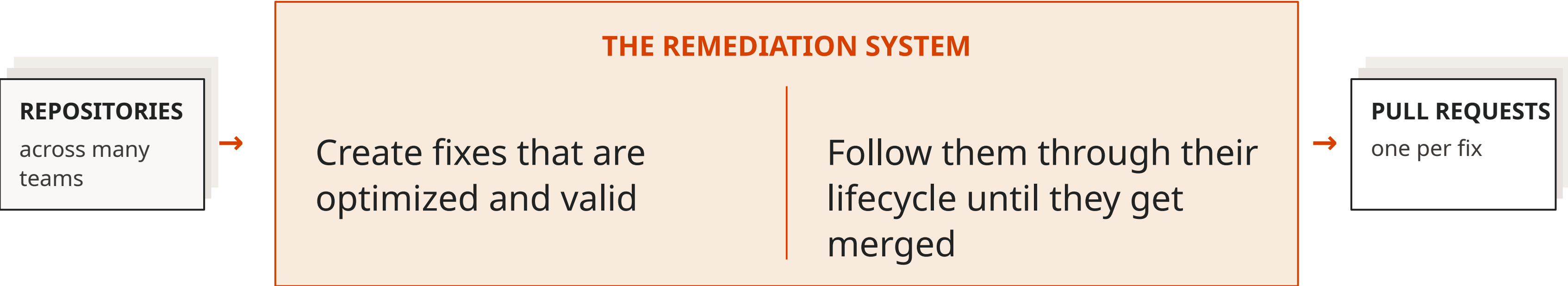
The more of the application a fix must understand, the less an assistant can prove it worked.



Conceptual model, not measured data

A valid fix does not scale by itself

Specialization is the engine. Scaling needs a system around it.



THE REMEDIATION BACKLOG

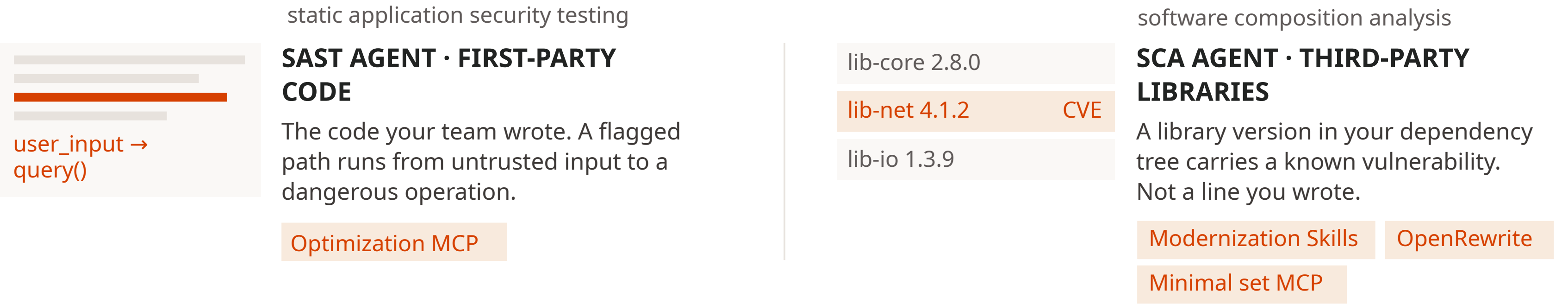
- ☐ merged
- ☒ PR green, waiting on a human
- ☒ PR red, the agent repairs it
- ☐ no PR yet



OUR APPROACH

Two specialist agents, one remediation system

SPECIALIZATION what it takes to get one fix right

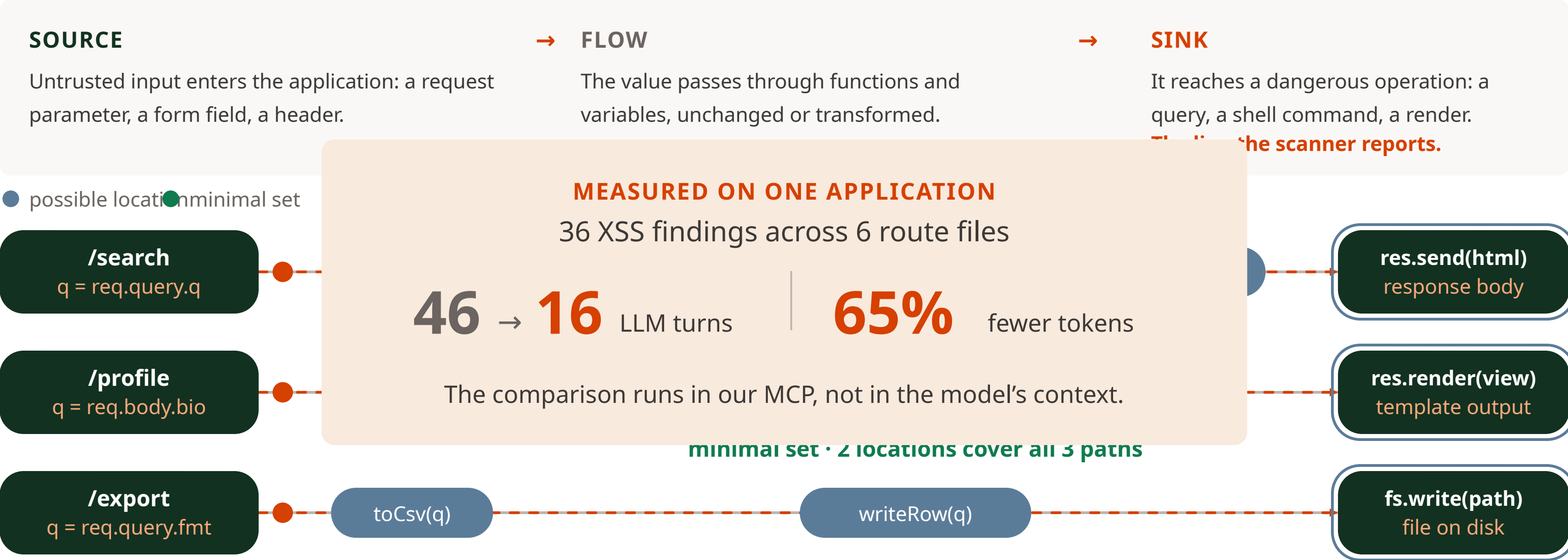


SCALE what it takes to run this everywhere



The best place to fix is rarely the place it was flagged

- 1 · Taint Analysis
- 2 · Possible Fixes
- 3 · The Minimal Set
- 4 · What It Costs



An SCA fix is a version change the application must survive

1 · THE FINDING

2 · THE MINIMAL SET

3 · THE CHANGE

4 · WHAT IT COSTS

THROUGHOUT THE ENTIRE PROCESS

41

the ver
edits s
nothing
OPEN
recip
- Up
- Ch
- Ch
Sam

AVERAGE INPUT PER FIX · SPRING BOOT 2.6.7 → 3.0.0, SEVERAL REPOSITORIES

Reading dependency files into context and reasoning through each upgrade is the expensive part.

40k → 560

tokens without tokens with OpenRewrite

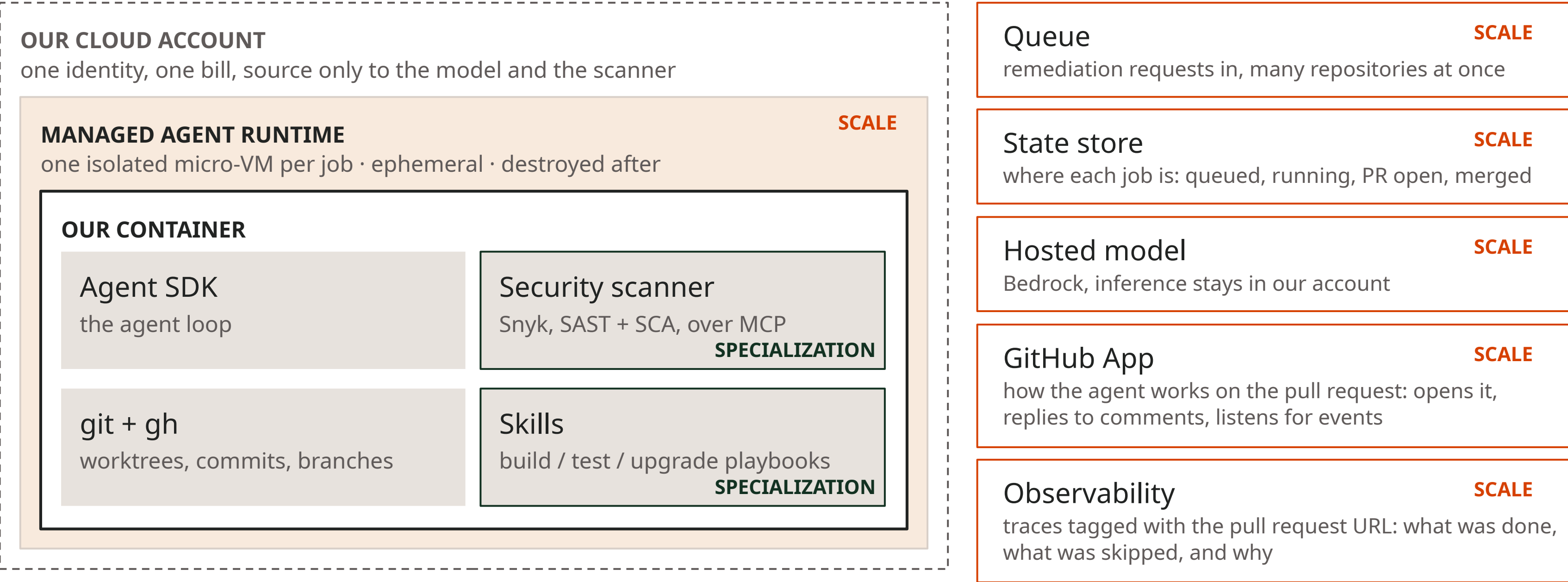
The dependency files never enter the model's context.

SMALLER BLAST RADIUS

LARGER BLAST RADIUS

Not only is it more expensive, but it also introduces more noise into the model's context, which is what is left.

One system underneath both agents



SPECIALIZATION what it takes to get one fix right **SCALE** what it takes to run this everywhere

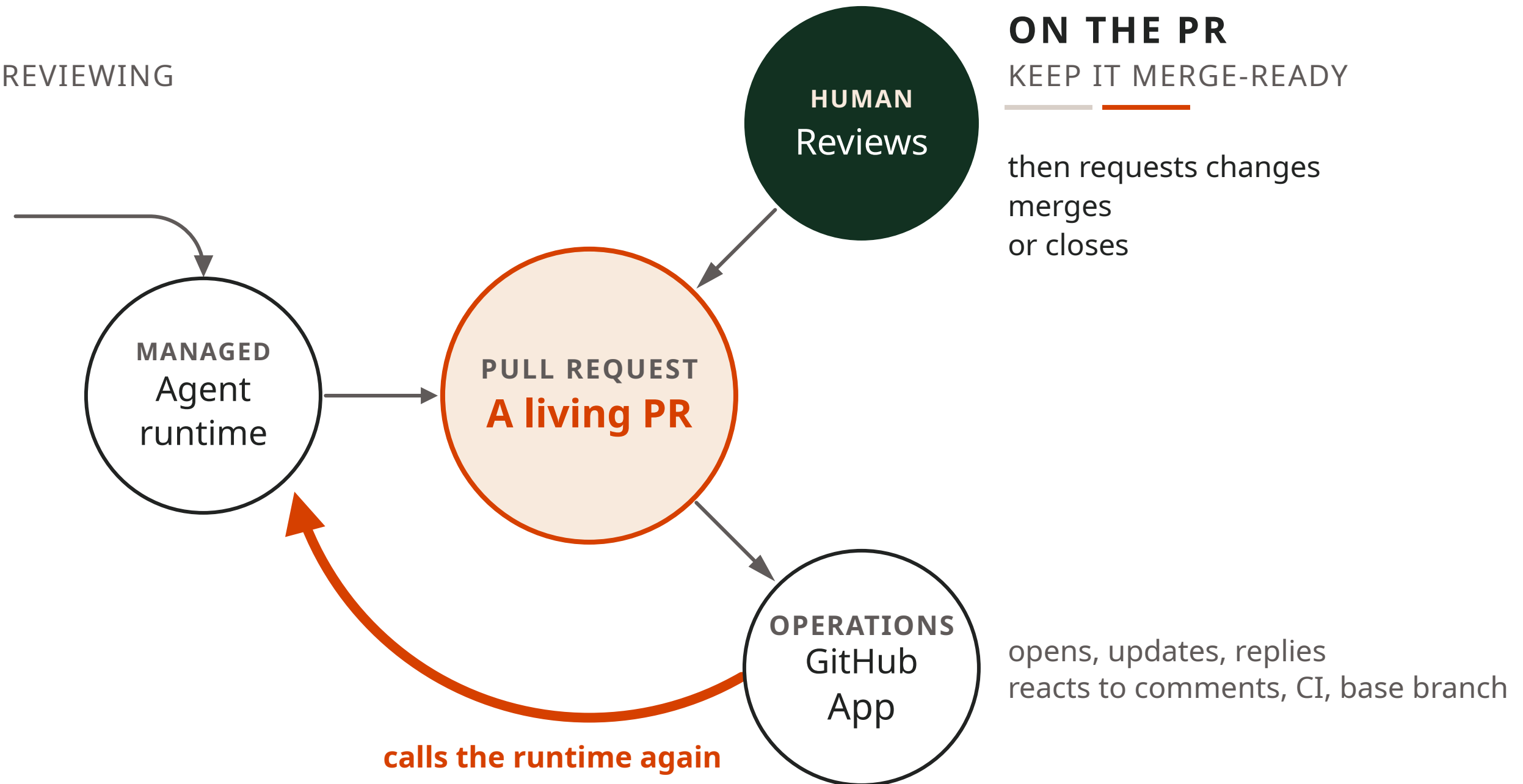
Two halves with the pull request in the middle

BEFORE THE PR

CREATE SOMETHING WORTH REVIEWING

TRIGGER

Trigger with a repository



ON THE PR

KEEP IT MERGE-READY

The system keeps the pull request worth reviewing; the human decides whether to merge it.

Planning: understand the repository before any change

1	2	3	4
DISCOVER	READ THE CONVENTIONS	BASELINE	SCAN, THEN PLAN
language, build system, and the projects inside the repository	the repository's own build and test conventions We treat these files as untrusted input.	run build and tests before anything changes Ground truth for what was already broken, so we can tell our failures from the repository's.	SAST batches findings by file and bug class. SCA builds an upgrade plan, at the blast radius the repository owner chose.

Nothing has changed in the code yet.

The model writes the fix, the checks judge it

1 · CHANGE

Only what the plan defines, inside an isolated copy of the repository.

2 · TWO CHECKS

No regression. Build and tests fail only where the baseline already did.

Fix proved. Findings counted per file and per bug class, before and after.

FINDINGS 3 → 0

NEW ISSUES 0 → 1

blocks · no pull request

3 · GATE

Both checks pass, or there is no pull request.

The system retries within a fixed budget. If the gate still fails, the change is reverted and nothing is published.

Correct is not the same as mergeable

fix(security): parameterise SQL queries in UserDao

AI Generated sast-remediation-agent

remediation/sast-sql-injection → main

SAST VULNERABILITY REMEDIATION

Three SQL injection findings in two files. Post-fix scan confirms all three resolved.

VULNERABILITY IMPACT

TYPE	FIXED	REMAINING
SQL Injection	3	0

FILES CHANGED

UserDao.java · parameterised SQL query
SearchServlet.java · added output encoding

REVIEW GUIDANCE

☐ Prepared statement binds every user input
☐ Encoding helper is the project's own

Linked to work item AB#1234 · tracks the remediation

BRANCH AND COMMIT RULES

PR STRUCTURE

WORK ITEM

Before we handled this, correct fixes were closed on format alone.

The pull request is the midpoint, not the finish

A pull request nobody maintains goes stale and is closed.

The finding goes back to the backlog.

REVISE

A reviewer asks for a change. The agent revises on the same branch and re-verifies.

SELF-HEAL

CI turns red or the base branch moves. The agent repairs, updates and re-verifies.

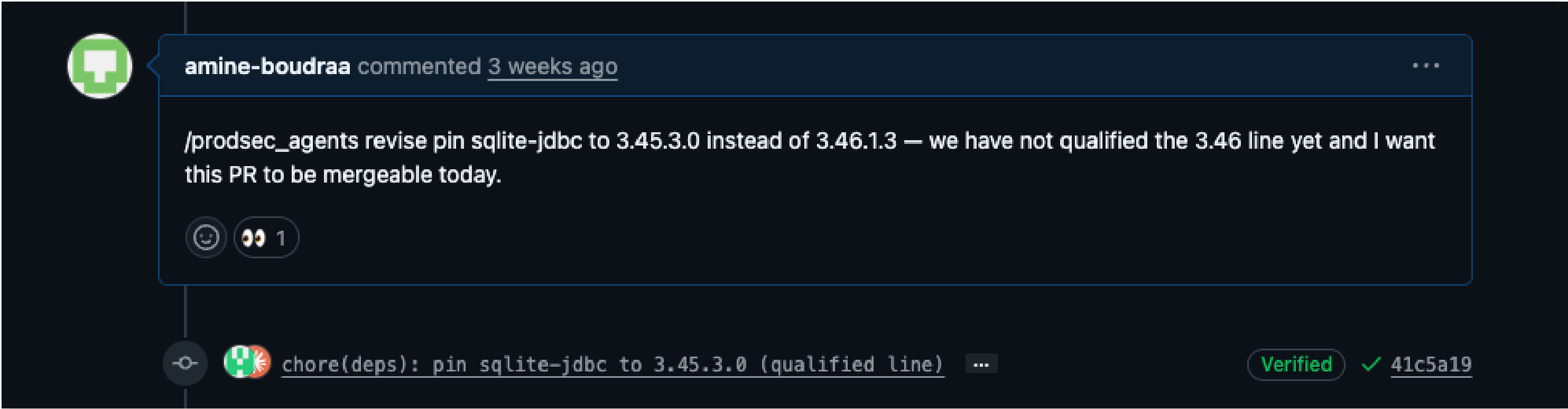
LEARN

Review comments and outcomes are collected. They change how we build the agents.

HUMAN CONTROL

The agent keeps the pull request ready. Only the repository owner merges or closes it.

Ask for changes without restarting the process



WHAT HAPPENS IN BETWEEN

Recover the context

The agent reads the thread and its own original plan, so it knows what it already changed and why.

Change the same branch

No second pull request. The review history and the conversation stay in one place.

Re-run the same verification

Build, tests and the scanner again. A comment does not get a shortcut past the gate.

Push and reply

The new commit and its evidence land on the same thread.

Developers used to close the PR and open a new one. Almost nobody added the changes by hand.

Nobody has to ask for any of this

EVENTS IT REACTS TO

CI goes red

Reads the failing job log, repairs the cause, re-verifies, pushes.

The base branch moves

Merges the new base into its own branch, re-verifies, pushes.

CI goes green

Green is not proof. If the repository's checks only scan secrets or metadata, the agent builds the change itself, or says in its reply that it did not.

WHAT IT CANNOT DO

Keeping a branch current is exactly when an agent would reach for rebase or force-push.

It cannot. A PreToolUse hook blocks the call before it runs. It is not an instruction a prompt can override.

force-push	cherry-pick	amend
-----------------------	------------------------	------------------

The same hook blocks gh pr merge and gh pr close, so the agent cannot merge or close its own pull request. That is enforced in code, not left to good behaviour.

Opening a pull request and walking away is what makes an agent untrustworthy.

Nothing gets thrown away

INSIDE ONE PULL REQUEST

Every comment and event is new input

review requests, replies, CI and base branch events

Each revision starts from everything before it

the full pull-request history, never from zero

What it picks up here changes what it does next, in this same pull request.

ACROSS EVERY PULL REQUEST

Every run is traced

Langfuse for the agent loop, Datadog for the platform, the GitHub App for what humans did on the pull request

Every signal feeds the next run

merges, closures, comments and recurring review patterns

One collection layer, and it is the track record. Per run it shows what the agent did and skipped. Aggregated, it shows where every repository stands.

Everything you have just seen is measured. So we can show you what developers actually merged.

CONCLUSION

Four things to take away

- 1 More code shipped plus better scanners equals a bigger backlog.
- 2 A coding assistant works when the fix is contained. It does not hold at enterprise scale.
- 3 Merged, not closed. The pull request only counts when it lands.
- 4 Use deterministic operations wherever you can.

WHAT DEVELOPERS MERGED

100

PRs merged in the last 2 weeks

70%

Merged

THE TEAM

The people who built this

Yassine Ilmi

Director Product Security & Security
Architecture

Ruchita Kshirsagar

Senior Product Security Engineer

Nihit Gupta

Senior Product Security Engineer

Piyush Chhiroliya

Senior Product Security Engineer

Raul Sandoval

Senior Product Security Engineer

Nicolai Nielsen

Product Security Architect

Efstathios Chouliaris

Manager in Software Development Engineering

Adam Drews

Staff Software Engineer I

Leonardo Axel Ortiz

Software Engineer I

OPEN SOURCE

Take the agents home

RUN IT

Try it on a real repository and tell us where it breaks.

EXTEND IT

Add a language or build tool through markdown playbooks.

SHAPE IT

Challenge the verification approach, refusal list and safe defaults.

Remediation agents:



MCP Scanner:



Codeflow solver:

